

Báo cáo lỗ hổng: Authentication Failures

1. Tên lỗ hổng

Authentication Failures (Lỗi xác thực người dùng)

OWASP Top 10: A07 – Authentication Failures

2. Mô tả lỗ hổng

Chức năng đăng nhập của hệ thống chỉ kiểm tra tính đúng đắn của tên đăng nhập và mật khẩu để cho phép người dùng truy cập. Tuy nhiên, hệ thống chưa triển khai các cơ chế bảo vệ cần thiết nhằm tăng cường an toàn cho quá trình xác thực, bao gồm:

- Không giới hạn số lần đăng nhập sai.
- Không khóa tài khoản sau nhiều lần đăng nhập thất bại.
- Không hỗ trợ xác thực đa yếu tố (Multi-Factor Authentication - MFA/2FA).

Những thiếu sót này làm tăng nguy cơ tài khoản bị chiếm đoạt thông qua các cuộc tấn công dò mật khẩu.

3. Mức độ ảnh hưởng

Mức độ: High (Cao)

Kẻ tấn công có thể thực hiện nhiều lần thử mật khẩu đối với một tài khoản mà không gặp bất kỳ giới hạn nào. Nếu người dùng sử dụng mật khẩu yếu hoặc bị lộ từ các vụ rò rỉ dữ liệu trước đó, khả năng bị đăng nhập trái phép sẽ tăng lên đáng kể.

4. Nguyên nhân

Hệ thống chưa triển khai các biện pháp bảo vệ quá trình xác thực như:

- Giới hạn số lần đăng nhập thất bại.
 - Cơ chế khóa tài khoản tạm thời.
 - Xác thực hai yếu tố (2FA/MFA).
-

5. Kịch bản khai thác

1. Kẻ tấn công biết hoặc đoán được tên đăng nhập của người dùng.
2. Sử dụng công cụ tự động (ví dụ: Burp Suite Intruder hoặc Hydra) để gửi liên tục các yêu cầu đăng nhập với nhiều mật khẩu khác nhau.

3. Do hệ thống không giới hạn số lần thử và không khóa tài khoản nên quá trình dò mật khẩu vẫn tiếp tục cho đến khi tìm được mật khẩu chính xác.
 4. Sau khi đăng nhập thành công, kẻ tấn công có thể truy cập trái phép vào tài khoản của nạn nhân.
-

6. Tác động

- Chiếm quyền truy cập tài khoản người dùng.
 - Rò rỉ thông tin cá nhân.
 - Thay đổi hoặc xóa dữ liệu.
 - Thực hiện các hành động trái phép dưới danh nghĩa người dùng hợp pháp.
 - Ảnh hưởng đến tính bảo mật, toàn vẹn và sẵn sàng của hệ thống.
-

7. Khuyến nghị khắc phục

7.1 Giới hạn số lần đăng nhập thất bại

- Chỉ cho phép từ 5–10 lần đăng nhập sai trong một khoảng thời gian nhất định.
- Sau khi vượt quá giới hạn, tạm thời từ chối các yêu cầu đăng nhập.

7.2 Khóa tài khoản tạm thời

- Khóa tài khoản từ 10–30 phút sau nhiều lần đăng nhập thất bại.
- Gửi thông báo đến người dùng khi tài khoản bị khóa.

7.3 Triển khai xác thực hai yếu tố (2FA)

- Yêu cầu thêm mã OTP từ ứng dụng như Google Authenticator hoặc Microsoft Authenticator sau khi nhập đúng mật khẩu.
- Đối với tài khoản quản trị, nên bắt buộc sử dụng 2FA.

7.4 Các biện pháp bổ sung

- Sử dụng CAPTCHA khi phát hiện nhiều lần đăng nhập thất bại.
 - Áp dụng Rate Limiting đối với API đăng nhập.
 - Ghi nhật ký (logging) và cảnh báo khi phát hiện nhiều lần đăng nhập thất bại từ cùng một địa chỉ IP.
-

8. Kết luận

Chức năng đăng nhập hiện tại chưa đáp ứng đầy đủ các yêu cầu bảo mật đối với quá trình xác thực người dùng. Việc thiếu cơ chế giới hạn số lần đăng nhập, khóa tài khoản tạm thời và xác thực hai yếu tố làm tăng nguy cơ bị tấn công dò mật khẩu và chiếm quyền tài khoản. Hệ thống cần triển khai các biện pháp bảo vệ nêu trên để giảm thiểu rủi ro và nâng cao mức độ an toàn theo khuyến nghị của OWASP Authentication Failures.